

Access Control Policy

Organization / Application: Personal Development Hub
Document owner: Application owner (sole operator)
Effective date: August 3, 2026
Review cadence: At least annually, and upon any material change to production access
Classification: Internal — may be shared with vendors for security due diligence (e.g., Plaid)

1. Purpose

This policy defines how access to production systems, credentials, and sensitive data is limited for Personal Development Hub (“the Application”), including systems that store or process financial account data obtained via third-party aggregators such as Plaid.

2. Scope

This policy covers:

- Production application hosting and deployment platforms
- Production databases and object storage
- Secrets, API keys, and environment configuration
- Vendor consoles related to production (including Plaid, hosting, and database providers)
- Source code repositories that can deploy to production

End-user account authentication within the Application is governed by the product’s authentication design and is summarized in Section 7.

3. Roles and responsibilities

Role	Responsibility
Application owner (sole operator)	Only person authorized to access production assets, approve changes, manage secrets, and respond to security incidents
End users	Access only their own Application data through authenticated sessions; no access to infrastructure or shared secrets

There are currently **no employees, contractors, or shared operator accounts** with production access. If that changes, this policy must be updated before granting access.

4. Access control principles

1. **Least privilege** — Production access is limited to what is required to operate and maintain the Application.
2. **Need to know** — Sensitive data (including financial transaction data and Plaid tokens) is accessible only through authorized systems and authenticated application APIs.
3. **Individual accountability** — Operator access uses personally attributable accounts (no shared generic logins for production consoles where avoidable).
4. **Defense in depth** — Access relies on vendor identity controls (passwords + multi-factor authentication where available), network HTTPS, and application session controls.

5. Production asset access controls

5.1 Allowed access

Only the Application owner may:

- Log into production hosting (e.g., Vercel) and trigger production deployments
- Access the production database console or connection strings
- View or rotate production environment variables and secrets
- Access the Plaid Dashboard and manage Plaid API credentials / Items
- Access the production Git repository settings that affect deployment

5.2 Authentication requirements for operator access

For all production-related vendor accounts (hosting, database, source control, Plaid, domain/DNS as applicable), the Application owner shall:

- Use a unique, strong password or password manager-generated credential
- Enable **multi-factor authentication (MFA)** wherever the vendor supports it
- Not share operator credentials with third parties

5.3 Secrets management

- Production secrets (session keys, database URLs, Plaid client ID/secret, webhook secrets, etc.) are stored in the hosting provider's encrypted environment variable store (or equivalent secrets manager).
- Secrets must **not** be committed to source control.
- Secrets are rotated when compromise is suspected, when personnel access changes, or as required by a vendor.
- Plaid access tokens and related financial data reside in the production database and are accessible only via authenticated server-side application logic.

5.4 Network and interface controls

- Production Application traffic is served over HTTPS.
- Administrative access to cloud vendors occurs through the vendor's authenticated web consoles or CLI using MFA-protected accounts.
- There is no standing open administrative VPN or bastion shared with a team (solo operator model).

6. Access reviews and lifecycle

6.1 Periodic review

At least **annually**, the Application owner shall review:

- Who has access to production hosting, database, source control, and Plaid
- That MFA remains enabled
- That unused API keys or tokens are revoked
- That environment variables and recovery credentials remain current and appropriately limited

6.2 Joiner / mover / leaver

Because production access is limited to the sole Application owner:

- **Joiner:** New production access is not granted without updating this policy and documenting the new role.
- **Mover:** Role changes that expand production access require explicit owner approval and documentation.
- **Leaver:** If any future operator access is granted and later ends, access must be removed the same day (vendor accounts disabled, secrets rotated, deploy keys revoked).

Automated HR de-provisioning systems are not applicable while there are no employees.

7. Application-level access to sensitive data (end users)

The Application enforces per-user isolation for end-user data:

- Users authenticate with email and password; passwords are stored using industry-standard one-way hashing (bcrypt).
- Authenticated sessions use signed HTTP-only session cookies.
- API routes that expose user data (including finance/Plaid-linked data) require a valid session and scope queries to the authenticated `userId`.
- Users cannot access another user's accounts, transactions, or Plaid Items through the Application APIs under normal operation.

This section describes product controls for customer data; it does not grant end users access to production infrastructure.

8. Monitoring and incident response (access-related)

If unauthorized access to production or secrets is suspected, the Application owner shall:

1. Revoke or rotate affected credentials (hosting, database, Plaid, session secrets) as applicable
2. Review recent deployments, database access, and Plaid Dashboard activity
3. Disable compromised Items or API keys in Plaid if financial-link credentials may be affected
4. Document the incident, remediation, and follow-up actions
5. Notify affected users and/or vendors when legally or contractually required

9. Exceptions

Any exception to this policy requires written approval by the Application owner, including rationale, compensating controls, and an expiration or review date.

10. Policy acknowledgment

By operating Personal Development Hub production systems, the Application owner acknowledges this Access Control Policy and is responsible for maintaining compliance with it.

Name / role	Signature	Date
Application owner	_____	_____

Document control

Version	Date	Summary
1.0	2026-08-03	Initial policy for vendor due diligence (solo operator model)